**Disciplina: Introdução à Criptografia**
**Lista de exercícios: Encontro 09 Criptografia autenticada AEAD**
**Aluno: Henrique C. de Andrade - JC3033732**
**Data: 11/10/2026**

### 1. Projete um registro de nota: classifique nota, versão, identificador do usuário, sequência, nonce e chave. Justifique o que cifrar e o que deixar visível autenticado. Que verificação liga o registro ao usuário esperado?

| Campo | Classificação | Tratamento |
|---|---|---|
| Nota | Mensagem secreta M | Cifrada e autenticada |
| Versão | Metadado público | AAD visível e autenticado |
| Usuário | Contexto público | AAD visível e autenticado |
| Sequência | Estado antirrepetição | AAD visível e autenticado |
| Nonce | Valor público único por chave | Guardado junto do registro |
| Chave | Segredo K | Fora do registro e protegida |

A nota deve ser cifrada porque é o conteúdo confidencial. Versão, usuário e sequência podem permanecer visíveis quando necessários ao roteamento e à validação, mas devem entrar no AAD para que qualquer alteração seja detectada. O nonce também é público, porém não pode se repetir em uma nova cifração sob a mesma chave. Depois de Open autenticar o registro, a aplicação deve decodificar o AAD e comparar o identificador autenticado com o usuário esperado pela operação. Uma etiqueta válida para o usuário 17 não autoriza aplicar a nota ao usuário 18.

### 2. Uma mensagem tem 23 bytes, AAD de 7 bytes, nonce de 12 e etiqueta de 16. Calcule o tamanho de C, da saída AESGCM e do registro completo. A chave de 16 bytes aumenta esse registro?

C mantém o comprimento da mensagem: |C| = 23 bytes.
A saída da biblioteca é C || T: 23 + 16 = 39 bytes.
Registro A || N || C || T: 7 + 12 + 23 + 16 = 58 bytes.
A chave de 16 bytes não aumenta o registro, pois deve ser armazenada e protegida separadamente, nunca transmitida no mesmo pacote.

### 3. Sem separadores, os pares (a, bc) e (ab, c) produzem o mesmo AAD. Escreva as duas representações com comprimentos de um byte e explique o limite e a validação necessários.

| Campos | Representação hexadecimal |
|---|---|
| (a, bc) | 01 61 02 62 63 |
| (ab, c) | 02 61 62 01 63 |

O byte anterior a cada campo informa seu comprimento e elimina a ambiguidade. Como o comprimento ocupa um byte, cada campo pode conter de 0 a 255 bytes. O decodificador precisa conferir se há bytes suficientes para cada comprimento declarado e rejeitar truncamento, valores excedentes ou representações fora da ordem definida. O protocolo também deve fixar a codificação dos textos e a versão do formato.

**Disciplina: Introdução à Criptografia**
**Lista de exercícios: Encontro 09 Criptografia autenticada AEAD**
**Aluno: Henrique C. de Andrade - JC3033732**
**Data: 11/10/2026**

### 4. Forme um nonce com prefixo 2 de quatro bytes e contador 255 de oito bytes, em big-endian. Escreva também o contador seguinte. Por que salvar o contador somente depois da cifração pode ser perigoso?

Prefixo 2 em quatro bytes: 00 00 00 02.
Contador 255 em oito bytes: 00 00 00 00 00 00 00 FF.
Nonce de 12 bytes: 00 00 00 02 00 00 00 00 00 00 00 FF.
Contador seguinte, 256: 00 00 00 00 00 00 01 00.
Se o processo cifrar e falhar antes de salvar o avanço, após reiniciar ele pode considerar 255 ainda disponível e reutilizar exatamente o mesmo nonce com a mesma chave. A reserva do contador deve ser persistida antes da cifração; perder um número é preferível a usá-lo duas vezes.

### 5. Para nonces uniformes de 64 bits e $q = 2^{20}$ mensagens, calcule aproximadamente lambda e P. Liste duas situações que invalidam a hipótese de sorteios independentes e uniformes.

$\lambda = q(q - 1) / (2 \cdot 2^{64})$.
Como $q = 2^{20}$, $q(q - 1) \approx 2^{40}$. Portanto, $\lambda \approx 2^{40} / 2^{65} = 2^{-25} \approx 2{,}9802 \times 10^{-8}$.
$P \approx 1 - e^{-\lambda}$. Como $\lambda$ é muito pequeno, $P \approx \lambda \approx 2{,}9802 \times 10^{-8}$, ou aproximadamente 0,0000029802%.
A hipótese deixa de valer, por exemplo, quando o gerador é defeituoso ou produz valores correlacionados e quando reinícios, restaurações de backup ou clonagem de máquinas repetem o estado do gerador. Outro caso seria haver vários emissores sem coordenação usando o mesmo espaço de nonces.

### 6. No modelo ideal, uma etiqueta de 64 bits sofre $2^{16}$ tentativas. Qual é a chance por tentativa e o limite acumulado? Explique por que isso não é uma análise completa da implementação.

Chance por tentativa: $2^{-64} \approx 5{,}4210 \times 10^{-20}$.
Limite acumulado: $2^{16} / 2^{64} = 2^{-48} \approx 3{,}5527 \times 10^{-15}$, ou cerca de 0,0000000000035527%.
Esse é apenas um limite de um modelo ideal de adivinhação. Ele não inclui reuso de nonce, volume e tamanho das mensagens, comprometimento da chave, falhas da biblioteca, erros de protocolo, vazamentos por canal lateral nem todos os termos da análise específica do GCM.

### 7. Um registro válido é recebido duas vezes. Open deve obrigatoriamente falhar na segunda vez? Indique onde guardar o controle de sequência e quando atualizá-lo.

Não. As duas chamadas recebem exatamente uma combinação válida de nonce, AAD, texto cifrado e etiqueta, então Open pode devolver a mensagem nas duas vezes. O bloqueio de replay pertence à aplicação ou ao protocolo. O receptor deve manter, em armazenamento persistente, as sequências já aceitas ou uma janela por usuário, emissor e chave. O estado só deve ser alterado depois de a autenticação e o contexto serem validados, mas a verificação, o registro da sequência e a efetivação da ação precisam formar uma operação atômica para impedir duas aceitações concorrentes.

### 8. Uma aplicação usa o cabeçalho recebido como AAD e aceita a etiqueta, mas não compara o usuário autenticado ao usuário da operação solicitada. Qual problema permanece? E se tentar imprimir M antes de Open retornar?

Permanece um erro de vinculação de contexto e autorização: um registro autêntico do usuário 17 pode ser aplicado indevidamente à operação do usuário 18. Autenticar o cabeçalho prova que seus bytes não foram alterados, mas a aplicação ainda precisa conferir se eles correspondem ao contexto esperado. Imprimir, interpretar ou executar M antes de Open retornar com sucesso usa texto não autenticado. Em uma API de alto nível, M nem deve ser disponibilizada antes do sucesso; se existir internamente um texto provisório, ele não pode escapar para a aplicação.

**Disciplina: Introdução à Criptografia**
**Lista de exercícios: Encontro 09 Criptografia autenticada AEAD**
**Aluno: Henrique C. de Andrade - JC3033732**
**Data: 11/10/2026**

### 9. Corrija: “AAD fica secreto, etiqueta válida prova qual pessoa enviou e nonce pode repetir se o texto for diferente”. Explique os três erros.

AAD não fica secreto: ele normalmente permanece visível e é autenticado contra alterações. Se um campo público revelar informação sensível, colocá-lo em AAD não elimina o vazamento.

Uma etiqueta válida não identifica necessariamente uma pessoa: ela mostra que alguém com acesso à chave simétrica produziu o registro. Se várias pessoas ou serviços compartilham a chave, qualquer um deles pode gerar uma etiqueta válida.

O nonce não pode se repetir sob a mesma chave nos esquemas estudados, mesmo que o texto seja diferente. A unicidade está ligada às operações de cifração sob a chave, não ao conteúdo da mensagem.

### 10. Desenhe um teste que altera separadamente C, T, AAD, nonce e chave. Acrescente os casos de mensagem repetida e de contexto errado. Quais devem falhar na biblioteca e quais pertencem à política da aplicação?

| Caso isolado | Resultado esperado | Responsável |
|---|---|---|
| Primeiro byte de C alterado | InvalidTag | Biblioteca AEAD |
| Último byte de T alterado | InvalidTag | Biblioteca AEAD |
| Último byte do AAD alterado | InvalidTag | Biblioteca AEAD |
| Último byte do nonce alterado | InvalidTag | Biblioteca AEAD |
| Abertura com outra chave | InvalidTag | Biblioteca AEAD |
| Registro original repetido | Open aceita; ação é recusada | Política antirreplay |
| Registro do usuário 17 usado como 18 | Open aceita; contexto é recusado | Política de contexto |

Cada alteração criptográfica deve partir de uma cópia nova do pacote original, mantendo todos os demais campos inalterados. Nenhum caminho que produza InvalidTag pode consumir texto candidato ou modificar o estado de sequências aceitas. Nos dois últimos casos, o registro permanece criptograficamente íntegro; por isso a biblioteca pode aceitá-lo, mas a aplicação deve rejeitar a ação.

**Disciplina: Introdução à Criptografia**
**Lista de exercícios: Encontro 09 Criptografia autenticada AEAD**
**Aluno: Henrique C. de Andrade - JC3033732**
**Data: 11/10/2026**

**Atividade 11 link repositorio**

https://github.com/henriquecarvalhodeandrade/criptografia/tree/main/encontro_09

**Explicações das tarefas práticas**

Tamanhos: M e C têm 8 bytes, o AAD tem 7, o nonce tem 12 e a etiqueta tem 16. Como encrypt devolve C seguido de T, pacote tem 24 bytes. A chave não é registrada na saída.

Os testes de adulteração partem sempre do pacote original. Alterar C, T, AAD, nonce ou a chave produz InvalidTag, e nenhum texto candidato é utilizado.

Os testes apenas chamam decrypt sobre cópias. Isso não cria uma nova cifração e, portanto, não reutiliza o nonce em uma nova operação Seal. A abertura legítima de um registro precisa usar o nonce que foi armazenado com ele.

Abrir duas vezes o mesmo pacote funciona na biblioteca porque a autenticação criptográfica continua válida. A segunda efetivação é bloqueada pelo conjunto de sequências aceitas.

O conjunto é consultado somente depois da autenticação e do teste de contexto. Se ocorrer InvalidTag, ele permanece inalterado.

O usuário é extraído do AAD autenticado e comparado ao usuário esperado. Um conjunto apenas em memória desaparece quando o processo reinicia e não é compartilhado entre instâncias. Sem transação ou bloqueio, duas execuções concorrentes podem consultar o mesmo estado antes que uma delas registre a sequência e ambas podem aceitar o replay.

Relação com a propriedade criptográfica: os testes confirmam que AEAD vincula mensagem, AAD, nonce e chave à etiqueta, fazendo alterações isoladas falharem antes de a mensagem ser usada. Ao mesmo tempo, a repetição intacta e o contexto errado demonstram que autenticidade criptográfica não substitui o estado antirreplay, a verificação do usuário e a autorização da aplicação.

## Desafio de fechamento

Um registro AEAD pode usar o formato versão || identificador de chave || usuário || sequência || nonce || texto cifrado || etiqueta. Versão, identificador de chave, usuário e sequência ficam visíveis, mas compõem o AAD para que alterações sejam detectadas; o identificador apenas orienta a busca controlada da chave e continua não confiável até a autenticação. O nonce também fica visível e deve ser único em cada nova cifração sob a mesma chave. A mensagem original é secreta e aparece no registro apenas como texto cifrado. A etiqueta é armazenada para verificar a combinação completa. A chave secreta não integra o registro: permanece em armazenamento protegido, como um cofre de chaves. O formato ainda deve definir comprimentos, ordem e codificação sem ambiguidade, e o receptor deve conferir usuário, sequência e repetição antes de efetivar a ação.